

ASSIGNMENT: ATTACK AND DEFEND WEB APPLICATION

Student Name: Umeh Paul

Date: January 18, 2026

Target System: PrestaShop 8.1.2 (Ubuntu 22.04)

1. PRESTASHOP ATTACK SIMULATION REPORT

A. Methodology

The assessment followed an "Attack and Defend" lifecycle. First, the application was deployed in a default state to identify vulnerabilities. Second, active attacks (SQLi, XSS, and Information Disclosure) were simulated from a Kali Linux machine. Finally, hardening measures and a Web Application Firewall (WAF) were implemented to block these vectors.

B. Exploited Vectors & Evidence

1. Information Disclosure (Debug Mode):

- **Vector:** Accessing the front-end while `_PS_MODE_DEV_` was set to `true`.
- **Evidence:** System exposed absolute file paths (`/var/www/html/...`) and database query structures.

2. SQL Injection (SQLi):

- **Vector:** Attempting to inject malicious SQL queries via search parameters.
- **Evidence:** Pre-mitigation, the system was susceptible to error-based discovery. Post-mitigation, the WAF intercepted the requests.

3. Cross-Site Scripting (XSS):

- **Vector:** Injecting `<script>alert('XSS')</script>` into contact forms.
- **Evidence:** WAF triggered an immediate 403 Forbidden response.

C. Mitigation & Logs

- **Hardening:** Renamed admin directory to `/admin-secret/`, changed DB prefix to `sec_`, and deleted the `/install` folder.
- **WAF Detection Log:**

```
[Mon Jan 17 14:22:10 2026] [-:error] [pid 1234] [client 192.168.2.100] ModSec
```

2. CONFIGURED WAF RULE FILE (ModSecurity)

The following configuration was applied to `/etc/modsecurity/modsecurity.conf` and the OWASP Core Rule Set was integrated.

Key Rule Configurations:

```
# Enable the WAF Engine
SecRuleEngine On

# Response for detected attacks
SecDefaultAction "phase:1,deny,log,status:403"

# Custom Rule: Block access to sensitive config files
SecRule REQUEST_FILENAME "\.env$" "id:1001,phase:1,deny,status:403,msg:'Sensitive"

# Custom Rule: Rate Limiting (Brute Force Protection)
# Limits requests to 100 per minute per IP
SecAction "id:9001,phase:1,nolog,pass,setvar:tx.rate_limit=100"
```

3. PRESTASHOP SECURITY CHECKLIST (COMPLETED)

Task	Status	Details
Admin Path	✔ PASS	Renamed to <code>/admin-secret/</code>
Debug Mode	✔ PASS	Disabled (Verified via <code>defines.inc.php</code>)
Install Folder	✔ PASS	Deleted from root directory
Permissions	✔ PASS	Folders: 755, Files: 644
DB Prefix	✔ PASS	Changed <code>ps_</code> to <code>sec_</code>
WAF Active	✔ PASS	ModSecurity + OWASP CRS 3.3.2
SQLi/XSS Block	✔ PASS	Verified with 403 Forbidden responses

4. DEFENSE VALIDATION REPORT

- **Success Indicators:** The primary "High Risk" finding (Debug Mode) was remediated, preventing information leakage.
- **WAF Performance:** The WAF successfully identifies and logs SQLi and XSS attempts using Anomaly Scoring mode.
- **Stability:** The site remains fully functional (`08-site-working-normally.png`) for legitimate traffic while blocking malicious patterns.

5. SCREENSHOT REFERENCES

(Please refer to the attached images provided in the 'screenshots' folder)

1. 02.0-debug-mode-ON.png: Evidence of initial vulnerability.
2. 06-waf-blocks-test.png: Evidence of successful attack blocking (403 Forbidden).
3. 07-waf-detection-logs.png: Evidence of the WAF identifying the specific attack vector.
4. 05-database-prefix.png: Evidence of database hardening.